

Chapter 12

Application Security

Why Application Security Matters

Top priority for management and decision makers

Secure apps before shipping to build client trust

Key methods: SAST, DAST, and Secure SDLC

Static Application Security Testing (SAST)

Reviews source code for vulnerabilities without executing it

Code is not running or changing state

Catches insecure patterns early in development

Dynamic Application Security Testing (DAST)

Tests live applications for real-time vulnerabilities

Detects data exposure and plain text credentials on the network

Includes stress testing and fuzzing with garbage inputs

OWASP SAMM

OWASP open framework for
improving software security

Analyzes and benchmarks an
organization's security posture

Embeds security into
development from day one

Secure Software Development Life Cycle

Process guided by SAMM to build security into every phase

Security ingrained, not an afterthought

In-house software ships secure out of the box